

System Design Specification

SDS

ระบบบริหารจัดการการยืม-คืนอุปกรณ์ มหาวิทยาลัย

University Equipment Lending Management System (ULMs)

Version 1.0

กันยายน 2569

ทีม: "miro ปั่น 14 บาท"

รหัสวิชา 01204341 Software Engineering

ภาควิชาวิศวกรรมคอมพิวเตอร์ คณะวิศวกรรมศาสตร์

มหาวิทยาลัยเกษตรศาสตร์

สารบัญ

1. General Product Description.....	4
1.1 Purpose.....	4
1.2 System Scope.....	4
2. System Requirement.....	5
2.1 Purpose.....	5
2.2 Use Case Model.....	5
2.3 Activity Model.....	6
2.3.1 Activity State.....	6
2.3.2 Activity Diagrams.....	7
3. System Specification.....	16
3.1 Purpose.....	16
3.2 Actors.....	16
3.3 Use Case Diagram.....	17
3.4 Use Case Specification.....	18
UC-03 ส่งคำขอยืม.....	18
UC-07 คืนอุปกรณ์และตรวจสอบสภาพ.....	19
4. System Analysis and Design.....	20
4.1 Purpose.....	20
4.2 Design Model.....	20
4.2.1 Use Case Realizations.....	20
4.2.2 Function Specification.....	21
4.3 Business Object Diagrams.....	23
4.4 Database Design Model.....	24
4.4.1 Class to Table Mapping.....	24
4.4.2 ER-Diagrams.....	25
4.4.3 Data Dictionary.....	25
5. System Decomposition.....	28
5.1 การแบ่งชั้นและองค์ประกอบของระบบ.....	28
5.2 External Interface.....	30
5.3 สัญญาระหว่างหน้าเว็บกับเซิร์ฟเวอร์.....	30
6. Data Store.....	31
6.1 System Log.....	31

6.2 Backup Cycle.....	31
7. Security.....	32
7.1 User Classification.....	32
7.2 Role Classification.....	32
7.3 User and Role Mapping.....	33
7.4 Administration Function.....	33
8. Authorization.....	34
9. System Recovery Procedure.....	36
10. System Installation and Deployment Procedure.....	37
10.1 ตัวแปรสภาพแวดล้อม.....	37
10.2 ขั้นตอนติดตั้ง.....	38
10.3 การตรวจอัตโนมัติและการทดสอบ.....	39
11. Back-out Procedure.....	39
ภาคผนวก ก: สถานะการพัฒนา ณ วันจัดทำเอกสาร.....	41

1. General Product Description

1.1 Purpose

เอกสารฉบับนี้แปลงความต้องการใน ULMs SRS ให้เป็นการออกแบบที่ลงมือสร้างได้จริง โดยระบุสเคส ผังกระบวนการ สถาปัตยกรรม โครงสร้างฐานข้อมูล รายการฟังก์ชันของระบบ การควบคุมสิทธิ์ และขั้นตอนการนำระบบขึ้นใช้งาน เพื่อให้ผู้พัฒนาทุกคนเห็นภาพเดียวกันและสร้างงานที่ประกอบเข้าด้วยกันได้ ทั้งยังใช้เป็นเกณฑ์อ้างอิงในการรีวิวก๊อดและออกแบบกรณีทดสอบ

1.2 System Scope

ULMs เป็นเว็บแอปพลิเคชันสำหรับบริหารจัดการการยืม-คืนอุปกรณ์และสถานที่ของมหาวิทยาลัยเกษตรศาสตร์ รองรับผู้ใช้ 4 บทบาท ครอบคลุมตั้งแต่ ค้นหาอุปกรณ์ ส่งคำขอยืม อนุมัติ จ่ายของ รับคืน ประเมินความเสียหาย จนถึงการจัดการเครดิตและการอุทธรณ์

อยู่ในขอบเขต	ไม่อยู่ในขอบเขต
บัญชีอุปกรณ์รายชั้นและสถานที่ สิทธิ์การเช่าใช้ตามหน่วยงาน	การจัดซื้ออุปกรณ์ใหม่และการเบิกจ่ายงบประมาณ
วงจรยืม-คืนเต็มรูปแบบ พร้อมหลักฐานภาพถ่าย	ระบบบัญชีการเงินและการเรียกเก็บค่าเสียหายเป็นตัวเงิน
ระบบเครดิต บทลงโทษ และการอุทธรณ์	การเชื่อมต่อกับระบบทะเบียนนักศึกษาโดยตรง

2. System Requirement

2.1 Purpose

หัวข้อนี้สรุปความต้องการที่การออกแบบต้องตอบ โดยยกมาจาก SRS ทุกข้อ มีรหัสที่อ้างอิงได้ตรงจากตารางในหัวข้อถัดไป

2.2 Use Case Model

ยูสเคสทั้งหมดของระบบ จัดกลุ่มตามผู้กระทำหลัก คอลัมน์สุดท้ายผูกกลับไปยังความต้องการใน SRS และคอลัมน์สถานะบอกว่ายูสเคสนั้นมีของจริงรองรับแล้วหรือยัง

รหัส	ยูสเคส	ผู้กระทำหลัก	ข้อกำหนด	สถานะ
UC-01	เข้าสู่ระบบและออกจากระบบ	ผู้ใช้ทุกบทบาท	FR-AUTH-01 ถึง 07	ใช้งานได้จริง
UC-02	ค้นหาและดูรายละเอียดอุปกรณ์	ผู้ยืม	FR-BRW-01 ถึง 05	ใช้งานได้จริง
UC-03	ส่งคำขอยืม	ผู้ยืม	FR-REQ-01 ถึง 10	ยังไม่มี procedure
UC-04	อนุมัติหรือปฏิเสธคำขอ	อาจารย์	FR-APV-01 ถึง 06	ใช้งานได้จริง
UC-05	จัดเตรียมและจ่ายอุปกรณ์	เจ้าหน้าที่, ผู้ยืม	FR-PKP-01 ถึง 05	ใช้งานได้จริง
UC-06	ต่ออายุการยืม	ผู้ยืม, อาจารย์	FR-RNW-01 ถึง 06	ฝั่งตัดสินทำได้ ฝั่งผู้ยืมยังไม่มี
UC-07	คืนอุปกรณ์และตรวจสอบสภาพ	ผู้ยืม, เจ้าหน้าที่	FR-RTN-01 ถึง 07	ใช้งานได้จริง
UC-08	อุทธรณ์ผลการประเมิน	ผู้ยืม, อาจารย์	FR-APL-01 ถึง 06	ยังไม่มี procedure
UC-09	ดูคะแนนเครดิตและประวัติการถูกหัก	ผู้ยืม	FR-CRD-01 ถึง 08	ใช้งานได้จริง
UC-10	จองล่วงหน้า	ผู้ยืม	FR-RSV-01 ถึง 06	ยังไม่มี procedure
UC-11	รับการแจ้งเตือน	ผู้ใช้ทุกบทบาท	FR-NTF-01 ถึง 06	ยังไม่มี procedure

รหัส	ยูสเคส	ผู้กระทำหลัก	ข้อกำหนด	สถานะ
UC-12	จัดการบัญชีอุปกรณ์และสถานที่	เจ้าหน้าที่	FR-EQP-01 ถึง 08	ใช้งานได้จริง
UC-13	จัดการผู้ใช้และบทบาท	ผู้ดูแลระบบ	FR-ADM-01 ถึง 03	ใช้งานได้จริง
UC-14	ตั้งค่าพารามิเตอร์ของระบบ	ผู้ดูแลระบบ	FR-ADM-04	ค่าตั้งการยืมทำได้ ค่าตั้งเชิงเทคนิคยังไม่มี
UC-15	ตรวจสอบ Audit Log และดูรายงาน	ผู้ดูแลระบบ	FR-ADM-05, 06	Audit Log ทำได้ รายงานยังไม่มี

2.3 Activity Model

2.3.1 Activity State

สถานะทั้งหมดของระบบเก็บเป็นชนิดข้อมูลแบบ enum ในฐานข้อมูล

ชุดสถานะ	ค่าที่เป็นไปได้	ใช้กับอะไร
ApproveStatus	Pending, Approved, Rejected, Canceled	คำขอยืม การจอง และคำขอต่ออายุ
CurrentStatus	Pending, Prepared, Lended, Returned, Inspected	วงจรชีวิตของการถือครองหนึ่งครั้ง (UsageLog)
ResourceStatus	InStorage, Lended, Missing	สถานะของสิ่งที่ยืมได้แต่ละชิ้น
ConditionType	Normal, MinorDamage, MajorDamage, Broken, Missing	ผลการตรวจสอบสภาพและสภาพปัจจุบันของทรัพยากร
PenaltyReason	DamagedItem, BrokenItem, LostItem, DidntReturn, ReturnLate	สาเหตุของการหักเครดิต

การเปลี่ยนสถานะของการยืมหนึ่งครั้ง เรียงตามลำดับที่เกิดขึ้นจริง

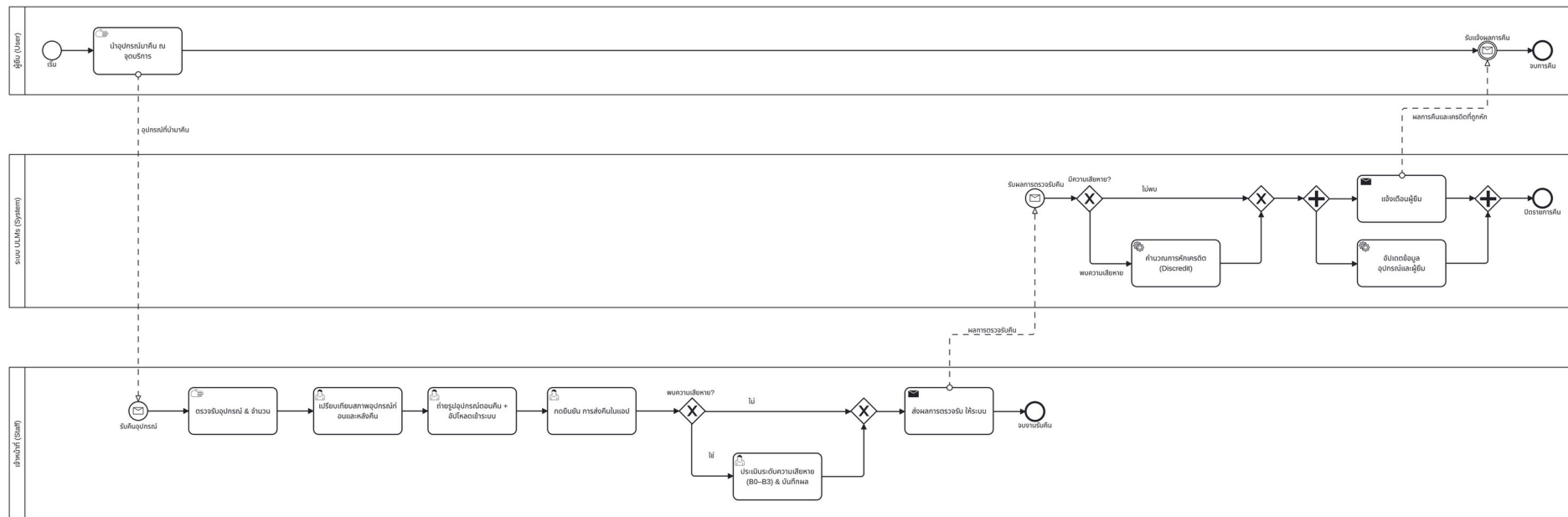
จากสถานะ	ไปสถานะ	ใครส่ง	เงื่อนไข
(ยังไม่มีแถว)	Pending	ผู้ยืม	ส่งคำขอผ่านการตรวจสอบสิทธิ์ เครดิต และของคงเหลือแล้ว
Pending	Approved	ระบบ หรือ อาจารย์	T0 และ T1 ของผู้ที่เครดิตดี อนุมัติอัตโนมัติ นอกนั้นอาจารย์ ตัดสินใจ
Pending	Rejected	อาจารย์	ต้องระบุเหตุผลประกอบ
Pending / Approved	Canceled	ผู้ยืม หรือ ระบบ	ผู้ยืมยกเลิกเอง หรือเลยกำหนด มารับ 24 ชั่วโมง
Approved	Prepared	เจ้าหน้าที่	เลือกขึ้นจริงและจัดเตรียมเสร็จ
Prepared	Lended	ผู้ยืม	ตรวจสอบ Serial Number และอัป โหลดรูปตอนรับแล้ว
Lended	Lended (เลื่อน กำหนด)	ผู้ยืม หรือ อาจารย์	คำขอต่ออายุได้รับอนุมัติ
Lended	Returned	ผู้ยืม	แจ้งคืนพร้อมรูปตอนคืน
Returned	Inspected	เจ้าหน้าที่	บันทึกผลตรวจสอบสภาพ ผู้ตรวจ ต้องไม่ใช่ผู้จัดเตรียม
Lended	(แจ้งของหาย)	เจ้าหน้าที่	ไม่คืนภายใน 2 สัปดาห์หลัง กำหนด

2.3.2 Activity Diagrams

ผังกระบวนการทั้งสี่ แต่ละแถวคือหนึ่งบทบาท สองกระบวนการแรกมีตาราง
ขั้นตอนกำกับไว้เพราะมีเส้นทางแยก

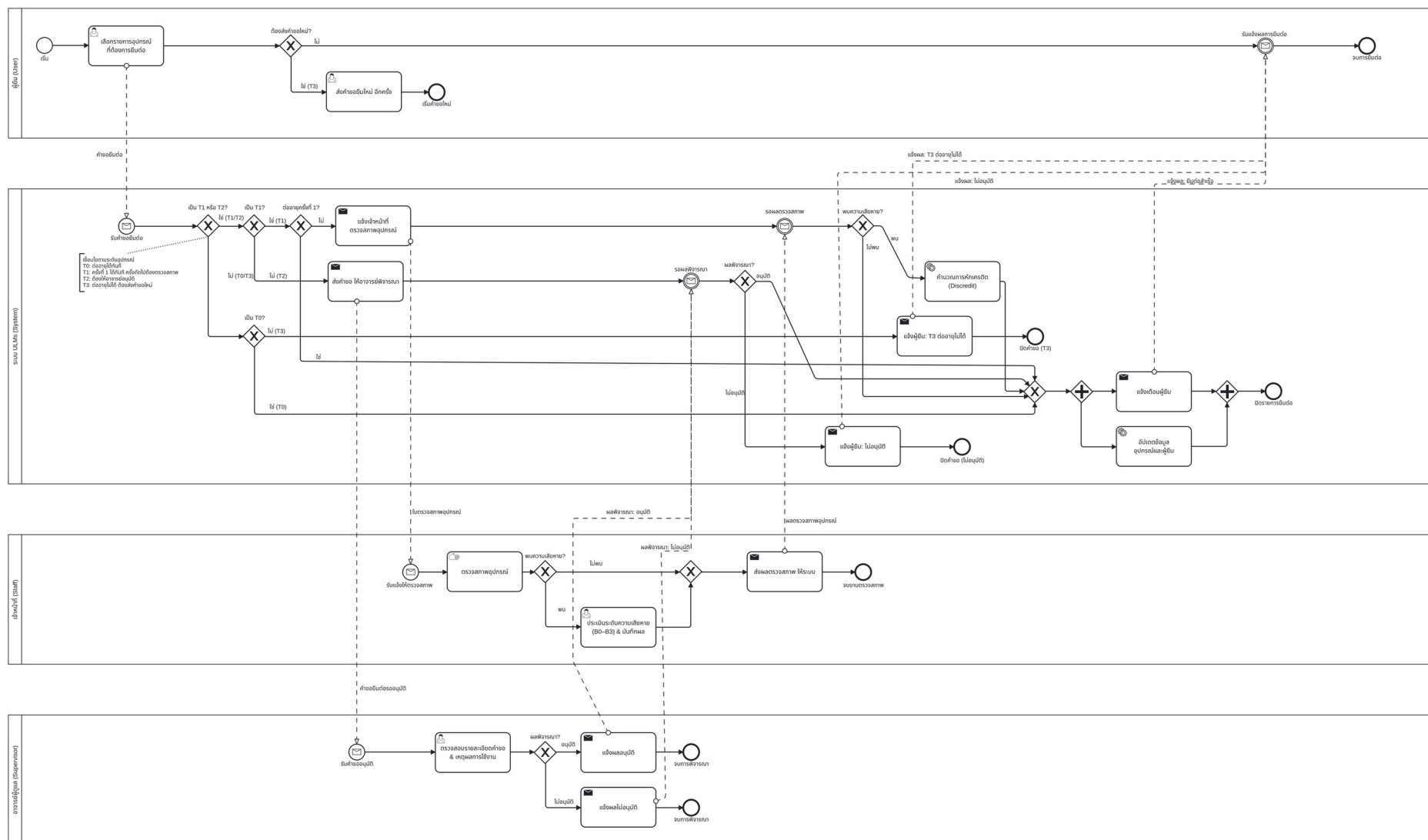
หน้า 8 / 41

ชั้น	ผู้ทำ	สิ่งที่ระบบทำ	ข้อกำหนด
1	ผู้ยืม	เลือกอุปกรณ์เข้าตะกร้า ระบุวันรับ-คืน แล้วส่งคำขอ ระบบตรวจสอบสิทธิการเข้าใช้จาก ตาราง Eligibility และตรวจสอบว่าระยะเวลาไม่เกินข้อกำหนด (กฎการยืม และระดับ เครดิต)	FR-BRW-01 FR-REQ-01 FR-REQ-02
2	ระบบ	ตรวจสอบคะแนนเครดิต จำนวนของที่ยังค้าง และของคงเหลือ ก่อนรับคำขอ	FR-REQ-03
3	ระบบ	เลือกเส้นทางอนุมัติ: T0 อนุมัติทันที T1 อนุมัติทันทีเมื่อเครดิตอยู่ D0-D1 T2 ส่งอาจารย์เสมอ	FR-REQ-04 ถึง 06
4	อาจารย์	อนุมัติหรือปฏิเสธเป็นรายชิ้นภายในคำขอ เดียว พร้อมเหตุผลเมื่อปฏิเสธ	FR-APV-02 FR-APV-03
5	ระบบ	สร้างการจัดสรร ตั้งกำหนดมารับ 24 ชั่วโมง แล้วแจ้งเตือนผู้ยืม ถ้าไม่มารับตามกำหนด ยกเลิกและปล่อยของกลับคลังอัตโนมัติ	FR-APV-05 FR-APV-06 FR-PKP-05
6	เจ้าหน้าที่ผู้ยืม	เจ้าหน้าที่เลือกชิ้นจริงตอนจัดเตรียม ผู้ยืม ตรวจสอบ Serial Number อัปโหลดรูปตอนรับ แล้วยืนยัน ระบบสร้าง UsageLog สถานะ Lended	FR-PKP-01 ถึง 03



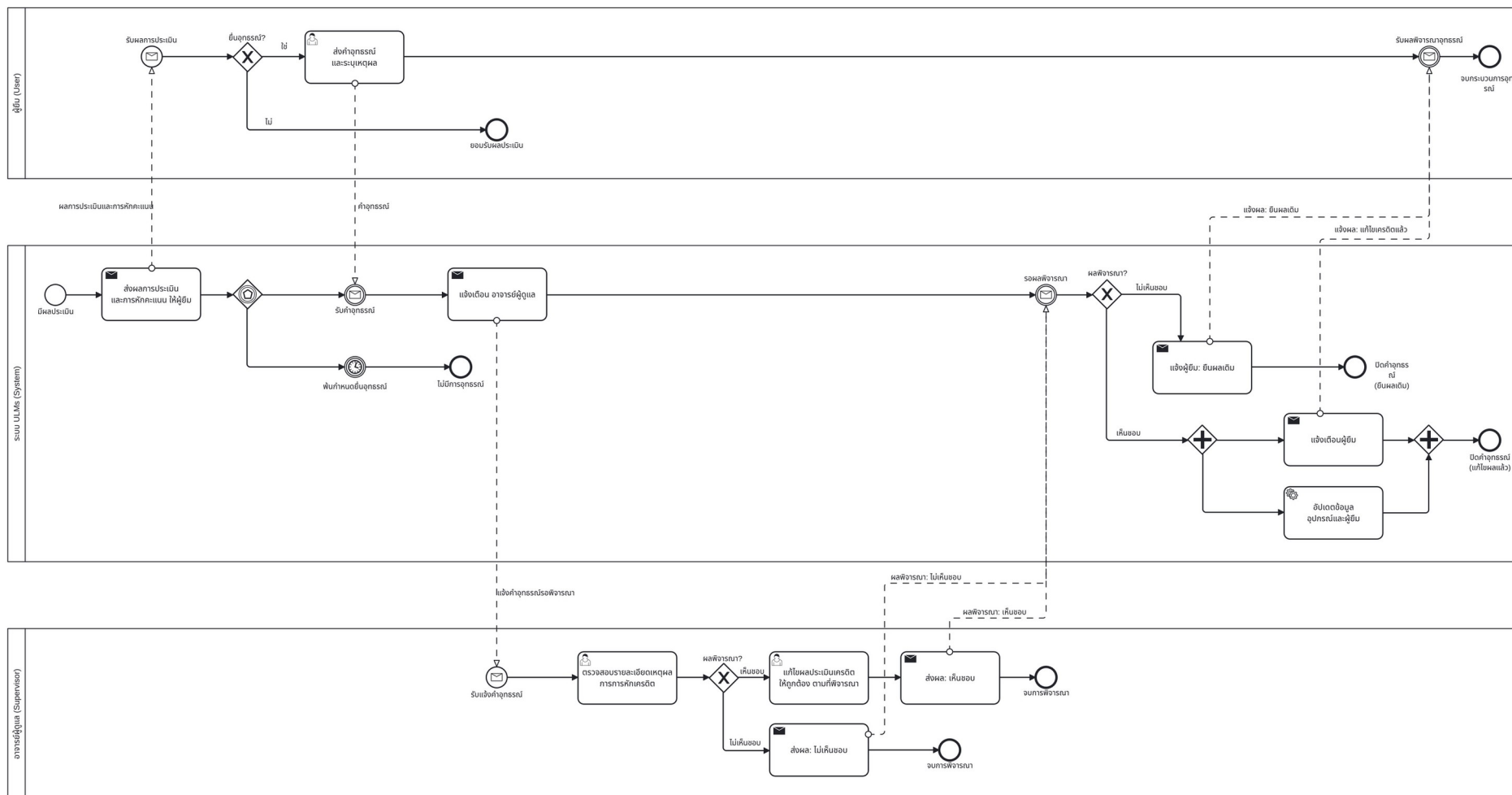
ผังกระบวนการคืนและตรวจสอบภาพ

ชั้น	ผู้ทำ	สิ่งที่ระบบทำ	ข้อกำหนด
1	ผู้ยืม	แจ้งคืนผ่านระบบพร้อมอัปโหลดรูปตอนคืน	FR-RTN-01
2	เจ้าหน้าที่	เปิดรูปตอนรับกับเทียบกับสภาพตอนคืน เทียบกับ	FR-RTN-02
3	เจ้าหน้าที่	บันทึกผลตรวจสภาพพร้อมหมายเหตุ ระบบเขียนแถวใหม่ใน Inspection และ ConditionLog	FR-RTN-03
4	ระบบ	ปฏิเสธการบันทึก ถ้าผู้ประเมินเป็นคนเดียวกับ ผู้จัดเตรียมของชิ้นนั้น	FR-RTN-04
5	ระบบ	ถ้าพบความเสียหายเกินระดับปกติ คำนวณ คะแนนที่ต้องหักแล้วสร้างแถวใน PenaltyInfo	FR-RTN-05
6	ระบบ	ถ้าคืนหลังเวลาทำการของเจ้าหน้าที่ ของวัน ครบกำหนด นับเป็นคืนซ้ำเพิ่มหนึ่งวันแล้ว คำนวณค่าปรับคืนซ้ำ	FR-RTN-07 FR- CRD-03
7	ระบบ	ปิด UsageLog เป็นสถานะ Inspected และ คืนทรัพยากรกลับสู่คลัง	FR-RTN-03



ผังกระบวนการต่ออายุการยืม

ชั้น	ผู้ทำ	สิ่งที่ระบบทำ	ข้อกำหนด
1	ผู้ยืม	กดขอต่ออายุจากรายการที่ยืมอยู่ ระบบแสดงกำหนดคืนใหม่ให้ดูก่อนยืนยัน	FR-RNW-05
2	ระบบ	ตรวจจำนวนครั้งที่ยืมกับ MaxExtendTime ของคู่ (กฎการยืมและ ระดับเครดิต)	FR-RNW-01
3	ระบบ	ตัดสินใจว่าต่อได้ทันทีหรือต้องให้อาจารย์อนุมัติ: ของรายชั้นที่มี Serial Number ต้องอนุมัติทุกครั้ง ผู้ที่เครดิตอยู่ D2-D3 ต้องอนุมัติทุกกรณี	FR-RNW-02 03 06
4	ระบบ	สร้างแถวใน ExtensionRequest โดยเก็บกำหนดคืนเดิมไว้ด้วย	FR-RNW-01
5	อาจารย์	อนุมัติหรือปฏิเสธ เมื่ออนุมัติ ระบบเลื่อน DueTime ใน UsageLog	FR-RNW-03



ผังกระบวนการอุทธรณ์

ชั้น	ผู้ทำ	สิ่งที่ระบบทำ	ข้อกำหนด
1	ผู้ยื่น	ยื่นอุทธรณ์ภายใน 7 วันนับจากวันที่เจ้าหน้าที่รายงานผล พร้อมเหตุผลและรูปเพิ่มเติม	FR-APL-01 FR-APL-02
2	ระบบ	สร้างแถวใน AppealInfo ผูกกับบtlngโทษเดิม หนึ่งบtlngโทษยื่นได้ครั้งเดียว	FR-APL-01
3	อาจารย์	ดูรูปก่อน-หลัง รายงานของเจ้าหน้าที่ และหลักฐานของผู้ยื่น จากหน้าจอเดียว	FR-APL-03
4	ระบบ	ปฏิเสธไม่ให้ผู้ประเมินคนเดิมเป็นผู้ตัดสินอุทธรณ์	FR-APL-04
5	อาจารย์	ตัดสิน ถ้าให้ผ่าน ระบบปิดบtlngโทษเดิม สร้างแถวใหม่ตามระดับที่ปรับแล้ว แล้วคำนวณคะแนนเครดิตใหม่	FR-APL-05 FR-APL-06

3. System Specification

3.1 Purpose

หัวข้อนี้ระบุว่าใครใช้ระบบบ้าง แต่ละคนทำอะไรได้ และยูสเคสหลักแต่ละตัวทำงานอย่างไรที่ละชั้น รายละเอียดระดับนี้คือสิ่งที่ผู้ทดสอบใช้เขียนกรณีทดสอบได้โดยตรง

3.2 Actors

ผู้กระทำ	คือใคร	ทำอะไรได้	ระดับความรู้
Borrower (ผู้ยืม)	นิสิตและบุคลากรที่มีบัญชีของมหาวิทยาลัย	ค้นหา ยืม รับ คืน ต่ออายุ อุทธรณ์ ดูเครดิตของตนเอง	ผู้ใช้ทั่วไป
Staff (เจ้าหน้าที่)	เจ้าหน้าที่ประจำภาค วิชาหรือชมรม	จัดการบัญชีอุปกรณ์ จัดเตรียมและจ่ายของ รับคืน ตรวจสอบภาพ บันทึกการซ่อม	ผ่านการอบรมเบื้องต้น
Supervisor (อาจารย์)	อาจารย์ผู้ดูแลหน่วยงาน	อนุมัติหรือปฏิเสธคำขอ ตัดสินการต่ออายุและการอุทธรณ์	ผู้ใช้ทั่วไป
Admin (ผู้ดูแลระบบ)	ผู้ดูแลระบบของภาค วิชา	จัดการผู้ใช้และบทบาท ตั้งค่าระบบ ดู Audit Log และรายงาน	มีความรู้ด้าน IT
System (ระบบ)	งานที่ทำงานตามเวลา โดยไม่มีคนสั่ง	ยกเลิกการจัดสรรที่เลย กำหนดมารับ อายุบทลงโทษ ส่งการแจ้งเตือนล่วงหน้า	—

เจ้าหน้าที่และอาจารย์ทำสิ่งที่ผู้ยืมทำได้ทั้งหมดด้วย (FR-AUTH-04) และทั้งสองบทบาททำงานได้เฉพาะกับทรัพยากรของหน่วยงานตนเองเท่านั้น (FR-AUTH-05)

3.3 Use Case Diagram



แผนภาพยูสเคสของระบบ ULMs «include» คือยูสเคสที่ถูกเรียกใช้เสมอ และ «extend» คือยูสเคสที่ทำงานเพิ่มในบางเงื่อนไข

3.4 Use Case Specification

ยกมาสองยูสเคสที่มีเส้นทางรองมากที่สุด ส่วนยูสเคสอื่นดูลำดับชั้นได้จากตารางใต้ผังกระบวนการ ในหัวข้อ 2.3.2 และดูรายการเต็มได้ที่หัวข้อ 2.2

UC-03 ส่งคำขอยืม

หัวข้อ	รายละเอียด
ผู้กระทำหลัก	ผู้ยืม
เงื่อนไขก่อนเริ่ม	ผู้ใช้เข้าสู่ระบบแล้ว และมีสิทธิ์เข้าใช้ทรัพยากรที่ต้องการตามตาราง Eligibility
เส้นทางหลัก	1) เลือกอุปกรณ์เข้าตะกร้าได้หลายรายการ 2) ระบุวันที่รับและวันที่คืน 3) ระบบตรวจระยะเวลา 1-14 วันและไม่เกินเพดาน (กฎการยืมและระดับเครดิต) 4) ระบบตรวจเครดิต ของค้าง และของคงเหลือ 5) ระบบตัดสินใจเส้นทางอนุมัติตามระดับอุปกรณ์ 6) บันทึกคำขอเป็นสถานะ Pending แล้วแจ้งผู้ยืม
เส้นทางรอง	4a) ของถูกคนอื่นตัดหน้าระหว่างกด → ยกเลิกทั้งรายการแล้วให้เลือกใหม่ 5a) เป็นอุปกรณ์ TO → อนุมัติทันทีโดยไม่ต้องรออาจารย์
เงื่อนไขหลังจบ	มีแถวใน Reservations สถานะ Pending หรือ Approved และของถูกกันไว้แล้ว
ข้อกำหนดที่ตอบ	FR-REQ-01 ถึง FR-REQ-10
สถานะการพัฒนา	ยังไม่มี procedure ผังเวิร์กโฟลว์ — เป็นงานที่ค้างอยู่ชิ้นสำคัญที่สุด

UC-07 คินอุปกรณ์และตรวจสอบสภาพ

หัวข้อ	รายละเอียด
ผู้กระทำหลัก	ผู้ยืม และเจ้าหน้าที่
เงื่อนไขก่อนเริ่ม	มีการถือครองสถานะ Lended อยู่
เส้นทางหลัก	1) ผู้ยืมแจ้งคินพร้อมอัปโหลดรูปตอนคิน 2) เจ้าหน้าที่เทียบรูปก่อน-หลัง 3) บันทึกผลตรวจสอบพร้อมหมายเหตุ 4) ระบบปิดการถือครองเป็นสถานะ Inspected และคินของเข้าคลัง
เส้นทางรอง	3a) พบความเสียหายเกินระดับปกติ → ระบบคำนวณคะแนนที่หักแล้วสร้างบทลงโทษ 3b) ผู้ตรวจเป็นคนเดียวกับผู้จัดเตรียม → ระบบปฏิเสธ 4a) คินหลังเวลาทำการ ของวันครบกำหนด → นับเป็นคินซ้ำเพิ่มหนึ่งวัน
เงื่อนไขหลังจบ	ทรัพยากรกลับเป็น InStorage และคะแนนเครดิตของผู้ยืมถูกคำนวณใหม่ถ้ามีบทลงโทษ
ข้อกำหนดที่ตอบ	FR-RTN-01 ถึง FR-RTN-07
สถานะการพัฒนา	ใช้งานได้จริง

4. System Analysis and Design

4.1 Purpose

หัวข้อนี้แปลงยูสเคสในหัวข้อ 3 ให้เป็นส่วนประกอบที่เขียนโค้ดได้ — ยูสเคสหนึ่งตัวถูกทำให้เป็นจริงด้วยหน้าจอใด เรียก procedure ใด และตารางใดบ้าง พร้อมรายการฟังก์ชันทั้งหมดของระบบและแบบจำลองฐานข้อมูล

4.2 Design Model

4.2.1 Use Case Realizations

แต่ละยูสเคสถูกทำให้เป็นจริงด้วยสามชั้นเสมอ: หน้าจอฝั่งผู้ใช้ procedure ฝั่งเซิร์ฟเวอร์ ตารางในฐานข้อมูล ตารางนี้คือแผนที่ที่ผู้ทดสอบอย่างเข้าด้วยกัน

ยูสเคส	หน้าจอ	procedure ฝั่งเซิร์ฟเวอร์	ตารางที่แตะ
UC-01 เข้าระบบ	/login	auth.login auth.me auth.logout auth.logoutAll	AccountInfo RoleInfo SessionInfo AuditLog
UC-02 ค้นหาอุปกรณ์	/catalog /catalog/:id /rooms	item.list item.getById item.getAvailability item.listUnits item.listRooms	ResourceInfo ItemInfo ItemIndiv RoomInfo Eligibility
UC-03 ส่งคำขอยืม	/request	— ยังไม่มี —	Reservations BorrowConstraints CreditTier
UC-04 อนุมัติคำขอ	/supervisor/ approvals	loan.staffQueue loan.getForStaff loan.allocate	Reservations UsageLog
UC-05 จ่ายอุปกรณ์	/staff/ handover /pickup	loan.allocate loan.swapUnit loan.confirmPickup image.requestUpload	UsageLog ItemIndiv Images
UC-06 ต่ออายุ	/my/loans	loan.extensionReviews loan.decideExtension (ฝั่งยื่นคำขอยังไม่มี)	ExtensionRequest UsageLog

ยูสเคส	หน้าจอ	procedure ฟังก์ชันเซิร์ฟเวอร์	ตารางที่แตะ
UC-07 คืบและตรวจสภาพ	/staff/inspection	loan.recordReturn loan.markLost inspection.create inspection.listForResource	UsageLog Inspection ConditionLog PenaltyInfo Images
UC-08 อุทธรณ์	/my/appeals /supervisor/appeals	— ยังไม่มี —	AppealInfo PenaltyInfo

4.2.2 Function Specification

ระบบมีฟังก์ชันที่เรียกใช้ได้จริง 67 รายการใน 7 โดเมน แต่ละรายการประกาศรูปร่างข้อมูลเข้าและออกด้วย zod schema ซึ่งตรวจก่อนถึงตรรกะทางธุรกิจเสมอ ข้อมูลที่ผิดรูปจึงไม่มีทางเข้าไปถึงฐานข้อมูล

โดเมน	จำนวน	ฟังก์ชัน	สิทธิ์ขั้นต่ำ
auth	4	login me logout logoutAll	สาธารณะ / ผู้ใช้ที่ล็อกอิน
admin	17	จัดการผู้ใช้ 8 ค่าตั้งการยืม 2 ค่าตั้งเชิงเทคนิค 2 สถานะระบบ 1 งานตามเวลา 2 audit 2	admin
item	24	ฝั่งผู้ยืม: ค้นหา ดูรายละเอียด ของคงเหลือ รายการขึ้น หมาดหมี่ สถานที่ — ฝั่งเจ้าหน้าที่: สร้างและแก้ไขประเภทขึ้น และสถานที่ เปิด-ปิดการให้ยืม กำหนดสิทธิ์การเข้าใช้	ผู้ใช้ที่ล็อกอิน / staff
loan	10	staffQueue queueCounts getForStaff allocate swapUnit confirmPickup recordReturn markLost extensionReviews decideExtension	staff / supervisor
inspection	9	list getById create listForResource recordRoomCheck listRepairs startRepair finishRepair proposeDecommission	staff

โดเมน	จำนวน	ฟังก์ชัน	สิทธิ์ขั้นต่ำ
credit	2	me getByld	ผู้ใช้ที่ล็อกอิน / staff
image	1	requestUpload	ผู้ใช้ที่ล็อกอิน

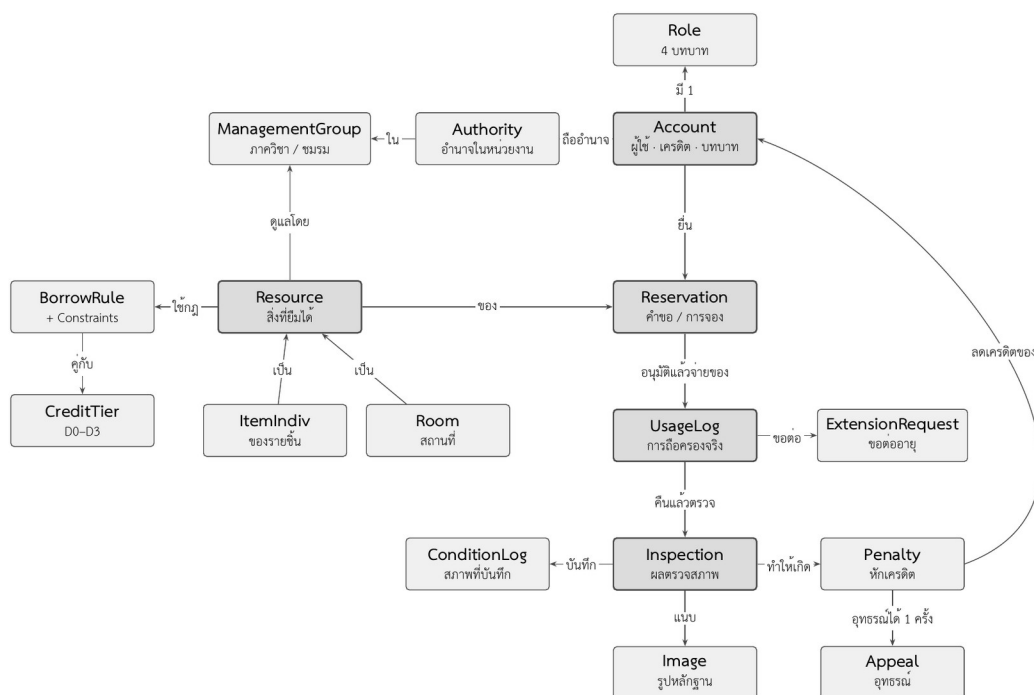
ส่วนที่ยังไม่มีฟังก์ชันฝั่งเซิร์ฟเวอร์เลยมี 5 กลุ่ม — การสร้างคำขอยืมฝั่งผู้ยืม (FR-REQ ทั้งกลุ่ม ซึ่งเป็นขั้นที่ทำให้วงจรยืมยังปิดไม่ครบ) การจอง (FR-RSV) การอุทธรณ์ (FR-APL) การแจ้งเตือน (FR-NTF) รายงาน (FR-ADM-06) ทั้งห้ากลุ่มมีตารางฐานข้อมูลรองรับไว้แล้ว เหลือเพียงการเขียนฟังก์ชันและหน้าจอ

สัญญาข้อผิดพลาด — ชั้น service รหัสสองชั้นพร้อมกัน

ชนิดของปัญหา	รหัสมาตรฐาน	ตัวอย่างรหัสเชิงธุรกิจ
ยังไม่ได้เข้าสู่ระบบ รหัสผ่านผิด	UNAUTHORIZED	NOT_AUTHENTICATED INVALID_CREDENTIALS
บทบาทไม่พอ อยู่นอก หน่วยงานที่ดูแล	FORBIDDEN	ROLE_NOT_ALLOWED OUT_OF_MANAGEMENT_SCOPE ACCOUNT_DISABLED
ของถูกตัดหน้า สถานะ ไม่ถูกจังหวะ	CONFLICT	RESOURCE_IN_USE WRONG_LOAN_STATE SERIAL_ALREADY_IN_USE
ไม่พบข้อมูล	NOT_FOUND	ITEM_NOT_FOUND LOAN_NOT_FOUND USER_NOT_FOUND
ลองเข้าสู่ระบบถี่เกินไป	TOO_MANY_REQUESTS	TOO_MANY_ATTEMPTS
ยังไม่ได้ทำ	NOT_IMPLEMENTED	NOT_IMPLEMENTED (ระบุว่าขาดอะไรไว้ในรายละเอียด)

การอัปเดตข้อมูลใช้การถามซ้ำตามรอบ ไม่ใช่ WebSocket — ของคงเหลือและสล็อตเวลาทุก 15 วินาที สถานะคำขอและคิวเจ้าหน้าที่ทุก 30 วินาที การแจ้งเตือนและคิวอาจารย์ทุก 60 วินาที ค่าทั้งหมดรวมไว้ที่ไฟล์เดียวเพื่อให้ปรับทั้งระบบได้จากจุดเดียว

4.3 Business Object Diagrams



แผนภาพ Business Object กล่องเข้มคือวัตถุแกนกลางที่กระบวนการอื่นอ้างอิง

วัตถุทางธุรกิจ	หมายถึง	กฎที่ผูกติดมาด้วย
Resource	สิ่งที่ยืมได้หนึ่งหน่วย	ผูกกับกฎการยืมหนึ่งชุดและหน่วยงานที่ดูแลหนึ่งกลุ่มเสมอ
Reservation	คำขอยืมหรือการจองหนึ่งครั้ง	มีกำหนดเวลามารับ ถ้าเลยกำหนดต้องถูกยกเลิกอัตโนมัติ
UsageLog	การถือครองจริงหนึ่งครั้ง	เกิดเมื่อของออกจากคลังเท่านั้น เก็บสภาพตอนรับและตอนคืนแยกกัน
Penalty	การหักเครดิตหนึ่งครั้ง	คะแนนปัจจุบันคือผลรวมของแถวที่ยังมีผล
Appeal	การอุทธรณ์หนึ่งครั้ง	หนึ่งบทลงโทษอุทธรณ์ได้ครั้งเดียว ไม่ลบของเดิมแต่สร้างของใหม่

4.4 Database Design Model

4.4.1 Class to Table Mapping

Business Object ในหัวข้อ 4.3 ลงเป็นตารางจริงอย่างไร

Business Object	ตารางจริง	หมายเหตุ
Account	AccountInfo	แยกบทบาทออกไปเป็นตาราง RoleInfo อำนาจในหน่วยงานอยู่ที่ Authority
Resource	ResourceInfo + ItemIndiv + RoomInfo	หนึ่งต่อหนึ่งทั้งสองทาง บังคับด้วย unique index
ItemType	ItemInfo	ประเภทอุปกรณ์ มูลค่าเครดิตที่ใช้ คำนวณค่าปรับอยู่ที่นี้
BorrowPolicy	BorrowRule + BorrowConstraints + PenaltyRule	แยกเป็นคู่ (กฎ × ระดับเครดิต) จึงปรับรายระดับได้
Reservation	Reservations	ครอบคลุมทั้งคำขอยืมและการจองล่วงหน้าในตารางเดียว
UsageLog	UsageLog	อ้างกลับไปยัง Reservations ที่เป็นต้นทาง
Inspection	Inspection + ConditionLog	ผลตรวจกับสภาพที่บันทึกแยกตารางกัน เพื่อให้สภาพถูกอ้างซ้ำได้
Penalty	PenaltyInfo	หนึ่งแถวคือหนึ่ง Demerit Event
Appeal	AppealInfo	ชี้ทั้งบทลงโทษเดิมและบทลงโทษใหม่
Evidence	Images	แยกชนิดด้วย SubmissionType ว่าเป็นรูปตอนรับ ตอนคืน หรือตอนตรวจ

ตาราง	ฟิลด์สำคัญ	หน้าที่และข้อสังเกต
Authority / AuthorityRole	AuthorityKey AccountKey ManageGroupKey AuthorityLevel	อำนาจของผู้ใช้ในหน่วยงาน — เป็นฐานของการจำกัดขอบเขต เจ้าหน้าที่
ItemInfo ItemIndiv RoomInfo	ItemInfo: ItemKey ItemName CreditWeight — ItemIndiv: IndivKey ResourceKey (unique) ItemID — RoomInfo: RoomKey ResourceKey (unique) RoomName RoomLocation	ItemID คือ Serial Number ทั้ง ของและสถานที่ผู้กลับไป ResourceInfo แบบหนึ่งต่อหนึ่ง
ResourceInfo	ResourceKey (PK) ManagedBy BorrowRule ConditionKey ResourceStatus ฯลฯ	สิ่งที่ยืมได้ BufferTime คือ prep_days
ConditionLog RepairLog Images Notification	ConditionLog: ResourceKey Condition LoggedBy — RepairLog: ช่วงเวลาซ่อม สภาพก่อน-หลัง — Images: SubmissionType ImageURL ผูกกับ UsageLog หรือ Inspection — Notification: NotificationType IsRead	บันทึกประกอบที่ทุกระบวนการ เขียนเพิ่มระหว่างทาง
BorrowRule BorrowConstra ints PenaltyRule CreditTier Eligibility	BorrowConstraints: BorrowRuleKey + CreditTierKey → MaxBorrowDate MaxExtendTime MinimumAuthorityLevel — PenaltyRule: PenaltyReason → PenaltyAmount PenaltyLength — CreditTier: CreditMin CreditMax — Eligibility: ResourceKey + GroupKey + RoleKey	กฎการยืมทั้งหมด BorrowConstraints เป็นตารางคู่ (กฎ × ระดับเครดิต) จึงปรับ เพดานรายระดับได้โดยไม่ต้องแก้ โค้ด
Reservations	ReservationKey (PK) ResourceKey ReservedBy StartTime EndTime ฯลฯ	คำขอและการจอง ReservationExpiration คือ กำหนดมารับ

ตาราง	ฟิลด์สำคัญ	หน้าที่และข้อสังเกต
UsageLog	UsageKey (PK) ReservationKey AccountKey ResourceKey CurrentStatus ฯลฯ	การถือครองจริง เก็บสภาพตอน รับและตอนคืนคนละคอลัมน์
ExtensionRequest	ExtensionKey (PK) UsageKey RequestedBy PreviousDueTime RequestedDueTime ฯลฯ	คำขอต่ออายุ
Inspection	InspectionKey (PK) UsageKey InspectorKey ConditionKey AppealKey ฯลฯ	ผลการตรวจสภาพ
PenaltyInfo	PenaltyKey (PK) AccountKey UsageKey CreditDeducted ExpirationTime ฯลฯ	บทลงโทษหนึ่งครั้ง
AppealInfo	AppealKey (PK) OriginalPenalty (unique) NewPenalty FiledBy ResolvedBy ฯลฯ	การอุทธรณ์
SessionInfo AuditLog	SessionInfo: TokenHash (unique) ExpiresAt RevokedAt — AuditLog: At ActorName ActorRole Action Target Ip	SessionInfo เก็บค่าแฮชของรหัส session ไม่ใช่ตัวรหัส AuditLog เก็บชื่อผู้กระทำซ้ำไว้ในแถว เพื่อ ให้อ่านออกแม้บัญชีถูกลบ

ข้อบังคับความถูกต้องที่ฐานข้อมูลเป็นผู้บังคับเอง ไม่ได้ฝากไว้กับโค้ด

ข้อบังคับ	บังคับที่ไหน	ป้องกันอะไร
Email และ UserID ต้องไม่ซ้ำ	unique index	ปัญหาซ้ำจากการสมัครพร้อมกันสองครั้ง ซึ่งตรวจในโค้ดอย่างเดียวกันไม่ได้
AppealInfo.OriginalPenalty ต้องไม่ซ้ำ	unique index	บทลงโทษหนึ่งครั้งอุทธรณ์ได้ครั้งเดียว
SessionInfo.TokenHash ต้องไม่ซ้ำ	unique index	การตรวจ session เหลือการอ่านดัชนีครั้งเดียว และกัน session ซ้ำค่า
การจัดสรรของอยู่ใน transaction เดียว	ชั้น service	สองคนได้ของชิ้นเดียวกันเมื่อกดพร้อมกัน (FR-REQ-09)
ผู้อนุมัติต้องไม่ใช่ผู้ขอ ผู้ตัดสินอุทธรณ์ต้องไม่ใช่ผู้ประเมินเดิม	ชั้น service	การอนุมัติงานของตัวเอง (FR-APV-04, FR-APL-04)

5. System Decomposition

5.1 การแบ่งชั้นและองค์ประกอบของระบบ

ระบบแบ่งเป็น 4 ชั้นตามข้อกำหนดของโครงการ แต่ละชั้นสื่อสารกับชั้นถัดไปเท่านั้น และไม่มีชั้นใดข้ามไปเรียกชั้นที่อยู่ห่างออกไปสองชั้น

ชั้น	หน้าที่	สิ่งที่ใช้จริง	ไฟล์
Client	เรนเดอร์หน้าจอ เก็บแคชฝั่งผู้ใช้ ตรวจสอบฟอร์มชั้นแรก	React 18 + Vite + TanStack Query	frontend/src/features/
API Server	รับคำขอ ตรวจสอบสิทธิ์ ตรวจสอบรูปร่างข้อมูล แปลงข้อผิดพลาด	nestjs-trpc ที่เส้นทาง /trpc	backend/src/*/*.router.ts
Application Server	ตรรกะทางธุรกิจ กฎการยืม การคำนวณเครดิต	NestJS service + mapper	backend/src/*/*.service.ts
Database Server	เก็บข้อมูลถาวร บังคับความถูกต้องระดับข้อมูล	PostgreSQL ผ่าน Prisma	backend/prisma/schema.prisma

ส่วนของระบบ	เทคโนโลยี	รุ่น	เหตุผลที่เลือก
หน้าเว็บ	React + Vite	18.3 / 5	ทีมคุ้นเคย build เป็นไฟล์สแตติกวางบน CDN ได้
ภาษา	TypeScript (strict)	5.x	ชนิดข้อมูลเดียวใช้ร่วมสองฝั่ง (NFR-MNT-01)
เซิร์ฟเวอร์	NestJS	11	โครงสร้างโมดูล เหมาะกับการแบ่งงาน 14 คน
สัญญา API	nestjs-trpc + @trpc/server	2.13 / 11.18	ใช้ชนิดข้อมูลเป็นสัญญา ไม่ต้องดูแลเอกสาร API แยก
ORM	Prisma	7.9	migration เป็นไฟล์ prepared statement กัน SQL injection
ฐานข้อมูล	PostgreSQL	16+	รองรับ transaction ระดับที่กฎการยืมชนกันต้องใช้
Session	โทเค็น HMAC-SHA256 ที่เขียนเอง + cookie-parser	—	เซ็นรหัสที่สุ่มมา เก็บในคุกกี้ httpOnly
CI	GitHub Actions	—	ตรวจ typecheck build และชุดทดสอบทุก pull request

หน้าจอฝั่งผู้ใช้แบ่งตามบทบาท และทุกเส้นทางถูกห่อด้วยสิทธิ์

กลุ่มเส้นทาง	ตัวอย่าง	บทบาทที่เข้าได้
สาธารณะ	/login	ทุกคน
ผู้ยืม (ฐานรวมของทุกบทบาท)	/ /catalog /catalog/:id /rooms /rooms/:id/book /rooms/use /request /pickup /my/loans /my/appeals /profile	ผู้ใช้ที่ล็อกอินทุกบทบาท
เจ้าหน้าที่	/staff /staff/handover /staff/inspection /staff/inventory	staff admin
จัดการหน่วยงานและรายงาน	/staff/users /staff/permissions /staff/settings /reports/analytics /reports/export	staff supervisor admin

กลุ่มเส้นทาง	ตัวอย่าง	บทบาทที่เข้าได้
อาจารย์ผู้อนุมัติ	/supervisor/approvals /supervisor/appeals	supervisor admin
ผู้ดูแลระบบ	/admin /admin/users /admin/status /admin/audit /admin/config /admin/settings /admin/reports	admin

5.2 External Interface

ส่วนติดต่อภายนอก	ใช้ทำอะไร	สถานะ
เบราว์เซอร์ของผู้ใช้	ช่องทางเข้าใช้งานเดียว ของระบบ รองรับ Chrome, Firefox, Safari, Edge	ใช้งานแล้ว
กล้องบนอุปกรณ์ผู้ใช้	ถ่ายรูปหลักฐานตอนรับ และตอนคืน ผ่านอินพุต ไฟล์ของเบราว์เซอร์	ใช้งานแล้ว
ที่เก็บไฟล์รูป	เก็บรูปหลักฐาน ปัจจุบัน เป็นดิสก์ของเซิร์ฟเวอร์เอง ที่ MEDIA_ROOT เซิร์ฟ ผ่านเส้นทาง /media	ใช้งานแล้ว
บริการส่งอีเมล	แจ้งเตือนล่วงหน้าก่อน ครบกำหนดคืน (FR- NTF-02)	ยังไม่เลือกผู้ให้บริการ
Google OAuth ของ มหาวิทยาลัย	ยืนยันตัวตนด้วยบัญชี @ku.th ตาม C-01 และ C-02	ยังไม่เชื่อมต่อ ปัจจุบันใช้บัญชี และรหัสผ่านในระบบเอง

5.3 สัญญาระหว่างหน้าเว็บกับเซิร์ฟเวอร์

สองฝั่งตกลงกันด้วยชนิดข้อมูลของ TypeScript ชุดเดียว ไม่มีไฟล์ระบุ API แยกต่างหาก การส่งฟิลด์ผิดหรือรับผลผิดรูปจึงควรถูกจับได้ตอนคอมไพล์ การส่งข้อมูลใช้ HTTP/JSON ผ่าน httpBatchLink ที่รวมหลายคำเรียกซึ่งเกิดพร้อมกันให้เป็นคำขอเดียว และแนบคุกกี้ session ไปทุกครั้ง

หัวข้อ	แบบที่ออกแบบไว้	สภาพจริงบน origin/main
เจ้าของสัญญา	ฝั่งเซิร์ฟเวอร์สร้างให้อัตโนมัติ	frontend/src/server/trpc-contract.ts เขียนด้วยมือ 233 บรรทัด(ชั่วคราว)
คำสั่งสร้าง	npm run contract:generate	ไม่มีสคริปต์นี้ใน backend/package.json
ตัวจับความต่าง	คอมไฟล์ไม่ผ่านเมื่อสองฝั่งไม่ตรงกัน	สองฝั่งขยับแยกกันได้โดยไม่มีอะไรเตือน

6. Data Store

6.1 System Log

ระบบเก็บบันทึกสองระดับที่มีจุดประสงค์ต่างกัน

ชนิดบันทึก	เก็บอะไร	เก็บที่ไหน
Audit Log	การกระทำที่เปลี่ยนสิทธิ์หรือข้อมูลสำคัญ: ใคร ทำอะไร กับอะไร เมื่อไร จากไอพีใด และด้วยเบราว์เซอร์ใด	ตาราง AuditLog ในฐานข้อมูล เก็บถาวร ไม่มีฟังก์ชันลบ
Application Log	ข้อผิดพลาดระดับระบบ และเหตุการณ์ระหว่างทำงาน	ปลายทางมาตรฐานของโปรเซส ตามนโยบายเก็บของผู้ให้บริการที่นำระบบขึ้น

6.2 Backup Cycle

ระบบมีข้อมูลสองก้อนที่หายไม่ได้ และทั้งสองก้อนต้องสำรองคู่กันเสมอ เพราะแถวในฐานข้อมูลที่ชี้ไปยังไฟล์รูปที่หายไปแล้วมีค่าเท่ากับหลักฐานที่ใช้ไม่ได้

สิ่งที่สำรอง	รอบ	เก็บย้อนหลัง	วิธี
ฐานข้อมูล PostgreSQL	ทุกวัน 03:00	14 วัน	dump เต็มฐาน แล้วเก็บนอกเครื่องที่รันระบบ
ไฟล์รูปหลักฐาน (MEDIA_ROOT)	ทุกวัน 03:00	14 วัน	คัดลอกเฉพาะไฟล์ที่เพิ่มใหม่
สคีม่าและ migration	ทุก commit	ตลอดอายุโครงการ	อยู่ในรีโปอยู่แล้ว ไม่ต้องสำรองแยก

สิ่งที่สำรอง	รอบ	เก็บย้อนหลัง	วิธี
ตัวแปรสภาพแวดล้อม	เมื่อเปลี่ยน	—	เก็บนอกรีโป ห้าม commit ค่าจริงเข้ารีโปเด็ดขาด

7. Security

7.1 User Classification

ประเภทผู้ใช้	ที่มาของบัญชี	ข้อสังเกตด้านความปลอดภัย
ผู้ใช้ทั่วไป (นิสิต/บุคลากร)	บัญชีในระบบ ผูกกับอีเมลของมหาวิทยาลัย	เป็นผู้ใช้ส่วนใหญ่ เข้าถึงได้เฉพาะข้อมูลของตนเองเท่านั้น
ผู้ใช้ที่มีอำนาจในหน่วยงาน	บัญชีเดียวกัน แต่มีแถวในตาราง Authority	เห็นข้อมูลของผู้อื่นได้เฉพาะในหน่วยงานที่ตนมีอำนาจ
ผู้ดูแลระบบ	กำหนดโดยผู้ดูแลระบบด้วยกัน	ไม่ถูกจำกัดขอบเขตหน่วยงาน ทุกการกระทำถูกบันทึกลง Audit Log
ผู้ไม่ได้เข้าสู่ระบบ	—	เรียกได้เพียง auth.login เท่านั้น และถูกจำกัดอัตราการเรียก

7.2 Role Classification

บทบาท	เก็บที่ไหน	ทำอะไรได้เพิ่มจากบทบาทก่อนหน้านี้	ขอบเขต
Borrower	RoleInfo.RoleName	ยืม รับ คืน ต่ออายุ อุดหนุน ดูเครดิตของตนเอง	เฉพาะข้อมูลของตนเอง
Staff	RoleInfo.RoleName	จัดการบัญชีอุปกรณ์ จ่ายของ รับคืน ตรวจสอบสถานะ บันทึกการซ่อม	เฉพาะหน่วยงานที่ตนมีอำนาจ
Supervisor	RoleInfo.RoleName	อนุมัติคำขอ ตัดสินการต่ออายุและการอุดหนุน	เฉพาะหน่วยงานที่ตนมีอำนาจ
Admin	RoleInfo.RoleName	จัดการผู้ใช้และบทบาท ตั้งค่าระบบ ดู Audit Log	ทั้งระบบ

7.3 User and Role Mapping

ผู้ใช้หนึ่งคนมีบทบาทระดับระบบได้หนึ่งบทบาท และมีอำนาจในหน่วยงานได้หลายหน่วยงานพร้อมกัน

ความสัมพันธ์	ตาราง	ความหมาย
ผู้ใช้ → บทบาท	AccountInfo.Role Key → RoleInfo	หนึ่งต่อหนึ่ง ตัดสินว่าเรียกฟังก์ชันกลุ่มใดได้
ผู้ใช้ → หน่วยงาน	Authority (AccountKey + ManageGroupKey)	หนึ่งต่อหลาย ตัดสินขอบเขตของข้อมูล ที่เห็นและแก้ไขได้
ทรัพยากร → หน่วยงาน	ResourceInfo.Man agedBy → ManagementGrou p	อีกครั้งหนึ่งของการตัดสินขอบเขต
ทรัพยากร → ผู้มีสิทธิ์ เยี่ยม	Eligibility (ResourceKey + GroupKey + RoleKey)	จำกัดว่าใครเยี่ยมทรัพยากรชิ้นนั้นได้

7.4 Administration Function

ฟังก์ชันผู้ดูแลระบบ	ทำอะไร	สถานะ
listUsers getUserById	ค้นหาผู้ใช้และดูประวัติการใช้งาน	ใช้งานได้จริง
changeRole	เปลี่ยนบทบาทของผู้ใช้ มีผลทันทีในคำขอถัดไป	ใช้งานได้จริง
setUserActive setUserBan	ระงับและคืนบัญชี บัญชีที่ถูกระงับใช้งานต่อไม่ได้ทันที	ใช้งานได้จริง
getLendingSettings updateLendingSettings	ปรับจำนวนวันยืม จำนวนครั้งที่ต่อได้ ช่วงคะแนนเครดิต และอัตราหักเครดิต	ใช้งานได้จริง
getConfig updateConfig	ค่าตั้งเชิงเทคนิค เช่น work_time	NOT_IMPLEMENTED
listAudit getAuditById	ดู Audit Log และกรองตามผู้กระทำ ชนิดการกระทำ ช่วงเวลา	ใช้งานได้จริง

8. Authorization

การควบคุมสิทธิ์ทำสามชั้นซ้อนกัน เส้นทางฝั่งหน้าเว็บตอบว่า “ควรเห็นเมนูนี้ไหม” middleware ฝั่งเซิร์ฟเวอร์ตอบว่า “เรียกฟังก์ชันนี้ได้ไหม” และชั้น service ตอบว่า “จัดการข้อมูลชั้นนี้ได้ไหม”

ตัวกรอง	เงื่อนไขที่ต้องผ่าน	ถ้าไม่ผ่าน
AuthMiddleware	ctx.user ต้องไม่เป็น null (มีคุกกี้ที่ยังไม่หมดอายุและยังไม่ถูกเพิกถอน)	UNAUTHORIZED — หน้าเว็บพาไปหน้าเข้าสู่ระบบ
StaffMiddleware	บทบาทเป็น staff หรือ admin	FORBIDDEN
SupervisorMiddleware	บทบาทเป็น supervisor หรือ admin	FORBIDDEN
AdminMiddleware	บทบาทเป็น admin	FORBIDDEN

การยืนยันตัวตนและการจัดการ session

หัวข้อ	การออกแบบ	เหตุผล
การเก็บรหัสผ่าน	script พร้อม salt เฉพาะบัญชีเก็บใน AccountInfo.HashPassword	ไม่เก็บรหัสผ่านจริง script ตั้งใจให้เข้าเพื่อกันการเดาสุ่ม
รูปแบบ session	สุ่มรหัส session แล้วเซ็นด้วย HMAC-SHA256 ตัวโทเค็นไม่พกข้อมูลผู้ใช้เลย	ต่อให้อ่านโทเค็นได้ก็ไม่ได้ ข้อมูลอะไร และปลอมไม่ได้ เพราะไม่มีกุญแจ
ที่เก็บฝั่งเซิร์ฟเวอร์	ตาราง SessionInfo เก็บค่าแฮช SHA-256 ของรหัส session พร้อมเวลาออก เวลาหมดอายุ และเวลาที่ถูกเพิกถอน	ฐานข้อมูลรั่วก็สวมรอยไม่ได้ เพราะค่าที่เก็บไม่ใช่ตัวรหัส
การเพิกถอน	ออกจากระบบ = ตั้งเวลาเพิกถอน logoutAll ล้างทุก session ของบัญชีเดียวในคำสั่งเดียว	ปิดช่องโหว่ที่โทเค็นแบบไร้สถานะทำไม่ได้ — บัญชีที่ถูกขโมยตัดได้ทันที
การตรวจทุกคำขอ	ตรวจลายเซ็น หา session ในฐานข้อมูล เช็การเพิกถอนและวันหมดอายุ แล้วอ่านบัญชีใหม่ทุกครั้ง	บทบาทที่เปลี่ยนและบัญชีที่ถูกปิดมีผลทันที ไม่ต้องรอโทเค็นหมดอายุ

หัวข้อ	การออกแบบ	เหตุผล
การกันเดารหัสผ่าน	นับความล้มเหลวในหน้าต่าง 15 นาที — เกิน 5 ครั้งต่อบัญชี หรือ 20 ครั้งต่อไอพี แล้วบล็อก 15 นาที	ตอบ NFR-SEC-05 สำหรับทางเข้าที่เรียกได้โดยไม่ต้องล็อกอิน
CORS	อนุญาตเฉพาะ origin ที่ระบุไว้ พร้อม credentials	ห้ามใช้เครื่องหมาย * คู่กับ credentials มิฉะนั้นเว็บใดก็ยังสามารถขอแทนผู้ใช้ที่ล็อกอินอยู่ได้

ความต้องการด้านความปลอดภัยใน SRS กับสิ่งที่การออกแบบนี้ตอบ

ข้อกำหนด	การออกแบบที่ตอบ	สถานะ
NFR-SEC-01	ให้บริการผ่าน HTTPS ทุกเส้นทาง คุกกี้ตั้ง secure อัตโนมัติในโหมด production	รอการนำขึ้นใช้งานจริง
NFR-SEC-02	รหัส session อยู่ในคุกกี้ httpOnly ฝั่งเซิร์ฟเวอร์เก็บเพียงค่าแฮช	ใช้งานแล้ว
NFR-SEC-03	ทุกฟังก์ชันประกาศ schema ของข้อมูลเข้า ข้อมูลผิดรูปถูกปฏิเสธก่อนถึงชั้น service	ใช้งานแล้ว
NFR-SEC-04	เข้าถึงฐานข้อมูลผ่าน Prisma เท่านั้น ซึ่งใช้ prepared statement	ใช้งานแล้ว
NFR-SEC-05	จำกัดการเดารหัสผ่านรายบัญชีและรายไอพี	ใช้งานแล้วเฉพาะทางเข้าสู่ระบบ
NFR-SEC-06	ขอตัวอัปโหลดที่เซ็นแล้วและมีอายุ 10 นาที ตรวจสอบไฟล์จากไบต์จริง ไม่ใช่จากนามสกุล ชื่อไฟล์เป็นค่าสุ่ม	ใช้งานแล้ว แต่เก็บลงดิสก์เอง ไม่ใช่ cloud storage ตามที่ SRS ระบุ
FR-AUTH-05	จำกัดขอบเขตจากส่วนร่วมของตาราง Authority กับเจ้าของทรัพยากร	ใช้งานแล้ว
FR-AUTH-07	บันทึก Audit Log ของการกระทำที่เปลี่ยนสิทธิ์และข้อมูลสำคัญ	ใช้งานแล้วในโดเมนผู้ดูแล การเข้าสู่ระบบยังไม่ครบ

9. System Recovery Procedure

ขั้นตอนกู้ระบบเรียงตามความรุนแรงของเหตุ จากเบาไปหนัก ทุกกรณีเริ่มด้วยการหยุดรับคำขอเขียนก่อนเสมอ เพื่อไม่ให้ข้อมูลใหม่ทับข้อมูลที่กำลังจะกู้

เหตุการณ์	ขั้นตอนกู้	เวลาที่ตั้งเป้า
บริการล่มแต่ข้อมูลยังดี	เริ่มโปรเซสใหม่ ตรวจสอบตัวแปรสภาพแวดล้อมครบ ตรวจสอบการเชื่อมต่อฐานข้อมูล	ภายใน 15 นาที
ฐานข้อมูลเสียหาย	หยุดบริการ กู้จากไฟล์สำรองล่าสุด รัน migration ให้ตรงรุ่นโค้ด ตรวจสอบจำนวนแถวของตารางหลัก เปิดบริการ	ภายใน 4 ชั่วโมง ข้อมูลหายไม่เกิน 1 วัน
ไฟล์รูปหลักฐานหาย	กู้โฟลเดอร์ MEDIA_ROOT จากไฟล์สำรอง ตรวจสอบว่าแถวในตาราง Images ชี้ไปยังไฟล์ที่มีอยู่จริง	ภายใน 4 ชั่วโมง
สงสัยว่าบัญชีถูกสวมรอย	เพิกถอน session ทั้งหมด ของบัญชีนั้น ตั้งรหัสผ่านใหม่ ตรวจสอบ Audit Log ย้อนหลัง	ทันที
กุญแจ SESSION_SECRET รั่ว	เปลี่ยนกุญแจแล้วเริ่มบริการใหม่ — session ทุกใบใช้ไม่ได้ทันที ผู้ใช้ทุกคนต้องเข้าสู่ระบบใหม่	ทันที

10. System Installation and Deployment Procedure

10.1 ตัวแปรสภาพแวดล้อม

ตัวแปร	ฝั่ง	ค่าเริ่มต้น	ใช้ทำอะไร
DATABASE_URL	backend	ไม่มี — ต้องตั้ง	ที่อยู่ของฐานข้อมูล PostgreSQL
SESSION_SECRET	backend	ไม่มี — ต้องตั้ง	กุญแจเซ็นรหัส session
SESSION_TTL_HOURS	backend	12	อายุของ session
COOKIE_SECURE	backend	false	บังคับคุกกี้ให้ส่งเฉพาะบน HTTPS (โหมด production เปิดให้เองอยู่แล้ว)
COOKIE_SAMESITE	backend	lax	ปรับเมื่อหน้าเว็บกับ API อยู่คนละโดเมน
MEDIA_ROOT	backend	./media	โฟลเดอร์เก็บรูปหลักฐาน
PUBLIC_API_URL	backend	http://localhost:3000	ใช้ประกอบ URL ของรูปให้หน้าเว็บเรียกได้
PORT	backend	3000	พอร์ตที่เซิร์ฟเวอร์ฟัง
NODE_ENV	backend	development	ตั้งเป็น production เพื่อเปิด secure cookie
VITE_TRPC_URL	frontend	/trpc	ปลายทางของสัญญา ตอนพัฒนาใช้ dev proxy ของ Vite

10.2 ขั้นตอนติดตั้ง

```
# 1 เตรียมฐานข้อมูล
createdb ulms

# 2 ตั้งเซิร์ฟเวอร์
cd backend
cp .env.example .env          # แล้วเติม DATABASE_URL และ SESSION_SECRET
npm ci
npx prisma generate
npx prisma migrate deploy      # ใช้ migrate dev เฉพาะตอนพัฒนา
npm run seed                   # ข้อมูลตั้งต้น: ระดับเครดิต บทบาท บัญชีทดสอบ
npm run build && npm run start:prod

# 3 ตั้งหน้าเว็บ
cd ../frontend
npm ci
npm run build                  # ได้ไฟล์สแตติกใน dist/ นำไปวางบนเว็บเซิร์ฟเวอร์
                                หรือ CDN
```

ขั้น	ตรวจอะไรก่อนไปต่อ	ถ้าไม่ผ่าน
หลังตั้งค่า	ตัวแปรที่ไม่มีค่าเริ่มต้นถูกตั้งครบ	เซิร์ฟเวอร์จะไม่ยอมเริ่มทำงานและบอกว่าขาดตัวใด
หลัง migrate	จำนวนตารางเท่ากับ 29	อย่ารันต่อ ตรวจว่ารูนั้โค้ดกับรูน migration ตรงกันไหม
หลัง seed	มีระดับเครดิตครอบคลุมช่วง 0-100 และมีบัญชีครบทุกบทบาท	การยืมจะพังด้วย CREDIT_TIER_NOT_CONFIGURED
หลังเปิดบริการ	เรียก auth.login แล้วได้คูกี้ เรียก auth.me แล้วได้ข้อมูลผู้ใช้	ตรวจ CORS และค่า COOKIE_SAMESITE

10.3 การตรวจอัตโนมัติและการทดสอบ

งานตรวจ	ตรวจอะไร	สถานะ
CI — ผังเซิร์ฟเวอร์	ติดตั้ง สร้าง Prisma client typecheck build migrate รันชุด ทดสอบ	รันทุก pull request
CI — ผังหน้าเว็บ	ติดตั้ง typecheck build	รันทุก pull request
ชุดทดสอบหน่วย ย่อย	service mapper session การแฮช ห้สผ่าน (Jest)	18 ไฟล์ รันใน CI แล้ว
ตรวจว่าสัญญาสอง ฝั่งตรงกัน	ไม่มีงานตรวจใดจับความต่างได้	ยังไม่มี — ดูหัวข้อ 5.3
ทดสอบครบระบบ และสมรรถนะ	เส้นทางหลักของ 4 บทบาท เป้า หมาย NFR-PRF	ตามแผน Sprint 5

11. Back-out Procedure

ขั้น	ทำอะไร	ข้อควรระวัง
1 ตัดสินใจ	กำหนดเกณฑ์ล่วงหน้าว่า อาการแบบใดถือว่าต้องถอย เช่น เข้าสู่ระบบไม่ได้ หรือ วงจรมีมั่ง	ตัดสินใจด้วยเกณฑ์ที่เขียนไว้ก่อน ไม่ใช่ ความรู้สึกตอนนั้น
2 หยุดรับคำขอ เขียน	ปิดทางเข้าใช้งานชั่วคราว	ถ้าไม่หยุดก่อน ข้อมูลใหม่จะเขียนลงส คิมาที่กำลังจะถอย
3 ถอยโค้ด	นำรุ่นก่อนหน้ากลับขึ้นใช้ งาน ทั้งฝั่งเซิร์ฟเวอร์และ ไฟล์สแตติกของหน้าเว็บ	ต้องถอยพร้อมกันทั้งสองฝั่ง เพราะ สัญญาระหว่างกันอาจเปลี่ยนไปแล้ว
4 ถอยสคิมา	ถ้ารุ่นที่ถอยไปใช้สคิมาเดิม ให้กู้ฐานข้อมูลจากไฟล์ สำรองก่อนนำขึ้นใช้งาน	migration ที่ลบคอลัมน์ทิ้งจะถอยไม่ ได้ ข้อมูลในคอลัมน์นั้นหายถาวร
5 ตรวจหลังถอย	เข้าสู่ระบบ ดูรายการอุปกรณ์ จ่ายของหนึ่งครั้ง รับคืนหนึ่ง ครั้ง	ถ้าเส้นทางใดไม่ผ่าน อย่าเปิดให้ผู้ ใช้เข้าจนกว่าจะแก้ไขเสร็จ
6 บันทึก	จดว่าอะไรพัง ถอยเพราะ อะไร และจะกันไม่ให้เกิดซ้ำ อย่างไร	ลงใน PROGRESS ของโครงการ

กฎการเขียน migration ให้ถอยได้ ใช้กับทุก migration ตั้งแต่ตอนนี้เป็นต้นไป

- เพิ่มคอลัมน์ใหม่ให้เป็นค่าว่างได้ หรือมีค่าเริ่มต้นเสมอ — รุ่นเก่าที่ไม่รู้จักคอลัมน์นั้นจะยังทำงานได้
- แยกการเพิ่มกับการลบออกจากกันคนละรอบ: รอบนี้เพิ่มของใหม่และเขียนสองที่ รอบหน้าค่อยลบของเก่า ทำแบบนี้แล้วรุ่นเก่ากับรุ่นใหม่อยู่ร่วมกันได้ระหว่างการนำขึ้นใช้งาน
- อย่าเปลี่ยนความหมายของคอลัมน์เดิม ให้เพิ่มคอลัมน์ใหม่แทน — การเปลี่ยนความหมายถอยกลับไม่ได้เลย
- สำรองฐานข้อมูลก่อนรัน migration ที่ลบหรือแก้ไขโครงสร้างทุกครั้ง ไม่มีข้อยกเว้น

ภาคผนวก ก: สถานะการพัฒนา ณ วันจัดทำเอกสาร

ส่วนของระบบ	สถานะ	หมายเหตุ
เข้าสู่ระบบ ออกจากระบบ ออกจากระบบทุกเครื่อง	ใช้งานได้จริง	session เก็บในฐานข้อมูล เพิกถอนได้ จำกัดการเดารหัสผ่านแล้ว
ฟังก์ชันฝั่งผู้ดูแลระบบ	ใช้งานได้จริง 15 จาก 17	getConfig และ runCronJob ยังโยน NOT_IMPLEMENTED
บัญชีอุปกรณ์และสถานที่ (item 24)	ใช้งานได้จริง	รวมสิทธิการเข้าใช้และการดูของคง เหลือ
วงจรมืม-คืนฝั่งเจ้าหน้าที่ (loan 10 inspection 9)	ใช้งานได้จริง	จ่ายของ เปลี่ยนขึ้น รับคืน แจ้งของ หาย ตรวจสอบภาพ ซ่อม
อัปโหลดรูปหลักฐาน (image 1)	ใช้งานได้จริง	เก็บลงดิสก์ที่ MEDIA ROOT ไม่ใช่ cloud storage ตามที่ SRS เขียนไว้
ฟังก์ชันสร้างคำขอยืมฝั่งผู้ ยืม	ยังไม่มี	ขั้นสุดท้ายที่ทำให้วงจรมืมปิดครบ (UC-03)
การจอง การอุทธรณ์ การ แจ้งเตือน รายงาน	ยังไม่มีฟังก์ชัน	มีตารางฐานข้อมูลอยู่แล้วทั้งหมด
เข้าสู่ระบบด้วยบัญชีของ มหาวิทยาลัย	ยังไม่เชื่อมต่อ	ปัจจุบันใช้บัญชีและรหัสผ่านในระบบ เอง (C-01, C-02)
สัญญาณระหว่างสองฝั่ง	ไม่ตรงกัน	หน้าเว็บใช้ไฟล์ที่เขียนมือ การสร้าง อัตโนมัติถูกถอดออกแล้ว — ดูหัวข้อ 5.3
คำแปลข้อความผิดพลาด	ตามไม่ทัน	รหัสฝั่งเซิร์ฟเวอร์ 49 ตัว มีคำแปล ไทยตรงกันเพียง 7 ตัว — ดูหัวข้อ 4.2.2
ระบบจัดระดับอุปกรณ์	ต้องตัดสินใจ	ยังมีสองวิธีจัดระดับซ้อนกัน — ดู หัวข้อ 4.4.1